

AUTH_SIMPLE_MODE — Sistema de Autenticación Simplificado

Introducción

Hammer POS/ERP usa un sistema de autenticación **basado en usuario y contraseña** con cookies firmadas (HMAC-SHA256). Este documento describe cómo funciona el flujo completo, desde el primer login hasta la gestión de usuarios.

Resumen del Flujo

1. Seed/Bootstrap → Crea usuario MASTER
 2. Login → Usuario ingresa credenciales
 3. Backend → Valida, genera cookie firmada
 4. mustChangePassword? → Redirige a /app/change-password
 5. Usuario cambia contraseña → Sesión revocada
 6. Re-login con nueva contraseña → Acceso completo

Credenciales por Defecto

Desarrollo (seed.ts)

Campo	Valor
Usuario	master
Contraseña	ElChele1234!
Rol	MASTER

Producción (seed-production.ts)

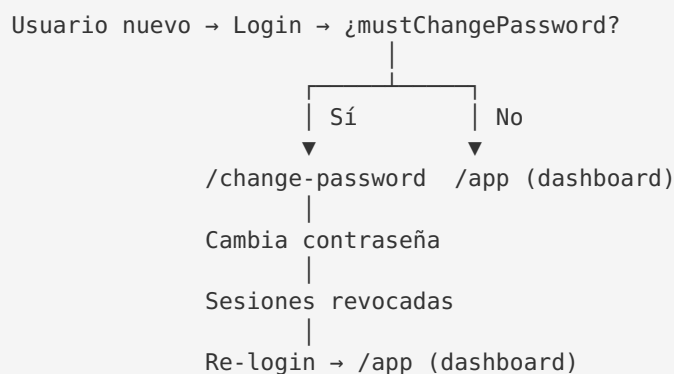
Variable de entorno	Obligatorio	Descripción
MASTER_INITIAL_USERNAME	No	Default: master
MASTER_INITIAL_PASSWORD	SÍ	Debe cumplir política de seguridad

 En producción, `MASTER_INITIAL_PASSWORD` es **obligatoria** y debe tener: min 10 caracteres, mayúscula, minúscula, número y símbolo.

Cómo Funciona el Primer Login

1. **Se ejecuta el seed** → Se crea el usuario MASTER con `mustChangePassword: false` (el master inicial ya conoce su contraseña)
2. **El master crea un nuevo usuario** → El usuario se crea con `mustChangePassword: true`
3. **El nuevo usuario hace login** → El backend detecta `mustChangePassword: true` y retorna `redirectTo: "/app/change-password"`
4. **El frontend redirige** → El layout de `/app/*` verifica `mustChangePassword` en la sesión y fuerza la redirección a `/app/change-password`
5. **El usuario cambia su contraseña** → El backend marca `mustChangePassword: false` y revoca todas las sesiones
6. **Re-login** → El usuario inicia sesión con su nueva contraseña y accede normalmente

Flujo visual



Cómo Crear Usuarios

Desde el Panel Master (`/app/master/users`)

1. Navegar a **Usuarios** en el menú master
2. Llenar el formulario:
 - **Usuario:** nombre único (ej: `juan.mga`)
 - **Nombre completo:** nombre real del empleado
 - **Correo:** opcional (se auto-genera `usuario@hammer.local` si está vacío)
 - **Contraseña inicial:** contraseña temporal (mín. 8 caracteres)
 - **Rol global:** `MASTER` o vacío (sin rol global)
3. Clic en **“Crear usuario”**
4. El usuario creado tendrá `mustChangePassword: true`
5. Compartir las credenciales temporales con el empleado
6. En su primer login, será forzado a cambiar la contraseña

Asignar Sucursal/Rol

Después de crear el usuario:

1. Seleccionarlo en la lista
2. En **“Asignar membresía”**, elegir sucursal y rol:

- `BRANCH_ADMIN` — Administrador de sucursal
- `SALES` — Ventas / POS
- `CASHIER` — Caja
- `WAREHOUSE` — Bodega

3. Clic en **“Asignar membresía”**



Cómo Resetear Contraseñas

Desde el Panel Master

1. Seleccionar el usuario en la lista
2. Usar el botón **“Resetear Contraseña”** que genera una contraseña aleatoria
3. Se muestra un modal con la nueva contraseña
4. **Copiar la contraseña** con el botón de copiar
5. Compartirla con el empleado
6. El usuario deberá cambiarla en su siguiente login (`mustChangePassword: true`)

Reset manual (campo de texto)

1. Seleccionar el usuario
2. Escribir una nueva contraseña en el campo
3. Clic en **“Guardar contraseña”**
4. El usuario deberá cambiarla en su siguiente login

Resetear Contraseña del Master (CLI)

```
# Desarrollo
cd hammer-api
npm run auth:reset-master

# Producción (con nueva contraseña)
MASTER_INITIAL_PASSWORD="NuevaContraseña1!" RESET_MASTER_PASSWORD=true npm run db:seed
:prod

# O usar el script dedicado:
npx tsx scripts/reset-master-password.ts "NuevaContraseña1!"
```

Variables de Entorno

hammer-api/.env

```
# Requerido – conexión a base de datos
DATABASE_URL="postgresql://..."

# Requerido – secreto para firmar cookies de sesión (mín 32 chars)
AUTH_SESSION_SECRET="tu-secreto-seguro-de-al-menos-32-caracteres"

# Opcional – TTL de sesión en horas (default: 8)
AUTH_SESSION_TTL_HOURS=8

# Bootstrap – para el seed de producción
MASTER_INITIAL_USERNAME=master
MASTER_INITIAL_PASSWORD=TuContraseñaSegura1!
BOOTSTRAP_BRANCH_CODE=MGA
BOOTSTRAP_BRANCH_NAME="Managua Central"
BOOTSTRAP_CREATE_CASH_BOX=true

# Para resetear contraseña master existente
RESET_MASTER_PASSWORD=false
```

hammer-frontend/.env

```
# URL del backend API
NEXT_PUBLIC_API_URL=http://localhost:4000
```

Troubleshooting

“Usuario o contraseña inválidos”

- Verificar que el username sea correcto (es case-sensitive)
- Verificar que el usuario esté activo (`isActive: true`)
- Si es la primera vez, usar la contraseña temporal proporcionada

“Demasiados intentos de inicio de sesión”

- El sistema tiene rate limiting (máx 5 intentos)
- Esperar el tiempo indicado en el mensaje
- Si es urgente, un administrador puede resetear el rate limit desde la DB

“Debes cambiar tu contraseña”

- Es normal en el primer login
- Ingresar la contraseña temporal como “Contraseña Actual”
- Crear una nueva contraseña que cumpla los requisitos

“La nueva contraseña no puede ser igual a la actual”

- Elegir una contraseña diferente a la actual

“AUTH_SESSION_SECRET_MISSING”

- Configurar la variable `AUTH_SESSION_SECRET` en el `.env` del backend

- Debe tener al menos 32 caracteres

“Base de datos no disponible”

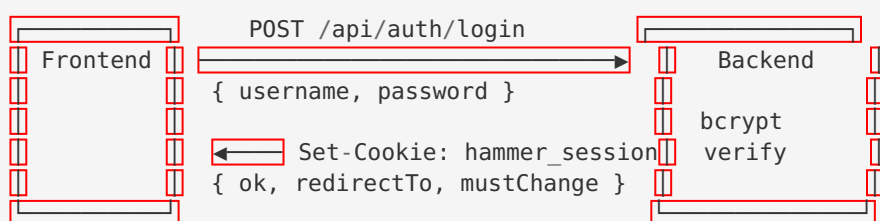
- Verificar que `DATABASE_URL` esté configurada correctamente
- Verificar que la base de datos esté accesible

El usuario no puede acceder a ninguna sección

- Verificar que tenga al menos una membresía activa (sucursal + rol)
- O que tenga un `globalRole` asignado (MASTER)



Arquitectura de Seguridad



Cookie: `hammer_session = HMAC-SHA256(payload)`

- `httpOnly`: `true`
- `secure`: `true` (producción)
- `sameSite`: `lax`
- `maxAge`: `AUTH_SESSION_TTL_HOURS * 3600`

Protección CSRF

- Todas las peticiones mutantes (POST, PUT, PATCH, DELETE) requieren token CSRF
- El token se obtiene automáticamente via `GET /api/auth/csrf`
- `apiFetch()` maneja esto transparentemente

Session Versioning

- Cada usuario tiene un `sessionVersion` counter
- Cuando se cambia contraseña, roles o se desactiva: `sessionVersion++`
- Tokens existentes con version anterior se rechazan automáticamente



Comandos Útiles

```

# Desarrollo
cd hammer-api
npm run db:seed                # Seed de desarrollo (master/ElChele1234!)
npm run auth:reset-master      # Reset contraseña del master
npm run dev                    # Iniciar servidor en localhost:4000

# Producción
npm run db:seed:prod           # Seed de producción (requiere MASTER_INITIAL_PASSWORD)
npm run prisma:migrate:deploy  # Aplicar migraciones
npm run build                  # Build de producción
  
```